

7.15 release Stack 05 — regular and Bitcoin-only product audit

1. Identity and frozen scope

- Owner: Codex /root, keepkey-vault-v11-agent-2. The coordination claim and master ledger are in the **main firmware worktree** at docs/release/audit-claims/715-05/OWNER.md and docs/release/MASTER-AUDIT-TEMPLATE.md. The main template SHA256 after claim was 7bd6bb9468dfa37175cd6007495d1d6a2d7b2f9f65d2fd437f89ef0ec003d1fe.
- Isolated worktree: /private/tmp/kk715-stack05-audit, branch audit/715-stack05-review. Code-bearing [audit PR #858](#) targets accepted Stack 04 at f05bfe96dad5a2deaf47437a5d3f5e40d6c352f.
- Historical product [PR #835](#) has original head dc644600361da15a123f0d50605220cccadd8de3 against original Stack 04 head 9e6c56c267c6755f55364f2a48073880b4f6f6e4. Its base predates Stack 04's accepted TRON/MayaChain repairs and handler tests. The single original Stack 05 commit replayed without conflict onto the accepted predecessor as fd033f6ef815e7e49964cbdd53212fb35ea46e37; release-note fix be2c04139 and report-gate fix 86ecb29ec follow it. PR #858 is the reviewable adjacent diff. No product branch was force-pushed or merged.
- No dependency pointer changed in this unit. Top-level pins: trezor crypto 8a392f70a5d5575ece3dfb35f115d4a4b27f497c, protocol dd9c85dc747cf965fb0e7bf49615dc9e7568ee65, Python host 49d537ce953b7524599bfc87f56b7a50a51a13a1, QR 6dfbfad5d9303ed190d1c3cb7bec34b565b6ce8, SecAES 71d356a1141624994cf613bd2d2583892e8e6d5a, signing keys a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec. The nested Python Ethereum list is 89a64f717e1690bb31adb3e4c38e23640357333c.
- The scoped contract is two 7.15 products: regular includes the Zcash shielded/Orchard engine and all supported non-Bitcoin chains; Bitcoin-only keeps only Bitcoin/Testnet, no non-Bitcoin message handlers or Zcash privacy, and retains Bitcoin signing. Release packaging must label each artifact and reproducibility command accurately. Physical devices, signed firmware upgrade, air-gapped signing and release promotion remain separate gates.

2. Immutable line inventory and behavior

Reproduce the original commit with `git show --format= --numstat --no-renames dc644600361da15a123f0d50605220cccadd8de3,` the audit fixes with the same command on be2c04139 and 86ecb29ec, and the adjacent net diff with `git diff --numstat f05bfe96dad5a2deaf47437a5d3f5e40d6c352f..86ecb29ec`. Source-report and PDF files appear only in the final adjacent diff; their final counts and containing SHA belong in the PR body because this file cannot contain its own commit identity.

Path	Original +/-	Audit fix +/-	Plain-language effect
.github/workflows/ci.yml	1/1	3/2 in report- gate fix	Adds the absent ERC-7730 runtime capability to the explicit staged-skip inventory, then shares that inventory with the report validator as well as Python integration.
.github/workflows/release.yml	3/9	6/15	Removes the separate Zcash-privacy matrix leg, packages regular and Bitcoin-only artifacts, and corrects the generated release body's regular filename and Bitcoin-only reproduction command.
CMakeLists.txt	1/8	0/2	Bumps version to 7.15.0, removes unconditional small AES tables; existing variant logic selects Zcash privacy and small AES tables for regular, neither for Bitcoin-only. Audit removes an orphaned comment.
docs/firmware/reviews/7.15.0-review-round2-remediation.md	23/7	0/0	Updates historical B1/B2 and variant statuses; source and tests below qualify these claims.
include/keepkey/firmware/app_confirm.h, app_layout.h	2/0 each	0/0	Guard Zcash display declarations under ZCASH_PRIVACY.
include/keepkey/transport/interface.h	1/1	0/0	Reorders protocol includes; no wire schema or pin changes.
lib/firmware/CMakeLists.txt	0/1	0/0	Removes Zcash from the general non-Bitcoin source list; the existing KK_ZCASH_PRIVACY branch adds it to regular only.
lib/firmware/fsm.c	8/5	0/0	Separates Zcash handlers from the generic non-Bitcoin include, and gives Bitcoin-only an inert signed_metadata_clear_signers definition for the common reset path.
lib/firmware/messagemap.def	18/17	0/0	Registers Zcash privacy messages only when compiled, keeps Hive under the non-Bitcoin guard, and preserves the EVM metadata guard.
lib/transport/CMakeLists.txt	7/7	0/0	Reorders Hive/Zcash nanopb generation consistently; protocol bytes are unchanged.
scripts/build/docker/device/release.sh	0/0	2/2	Corrects the comment to name the supported Bitcoin-only CMake flag; the existing script already passed flags through.

Path	Original +/-	Audit fix +/-	Plain-language effect
scripts/generate-test-report.py	0/0	5/8 in report-gate fix	Updates the report wrapper's comments to match the shared capability inventory. The validator's behavior is unchanged.
unittests/firmware/storage.cpp	1/2	0/0	Formatting-only change to the Bitcoin-only migration test.

The audit preflight also checked the complete adjacent `BASE..HEAD` name-status and numstat ranges, not just these source files. The report source, PDF, and named skip inventory are evidence paths in the final PR diff.

3. Security and product-boundary closure

Contract	Value, observer, variant and phase	Entry path, positive/negative evidence, attempted falsification and disposition
S05-1, Bitcoin-only isolation	The device seed, derived keys and transaction signatures belong to the user. A host must not obtain altcoin keys/signatures from the Bitcoin-only product, nor cause non-Bitcoin signing by sending a message number or a Zcash shielded request. Bitcoin and Testnet signing remain allowed.	KK_BITCOIN_ONLY=ON forces KK_ZCASH_PRIVACY=OFF, strips non-Bitcoin source and message rows, and keeps the common reset path linked with inert metadata cleanup. The 11/11 <code>test_msg_bitcoin_only_variant.py</code> tests ran against the Bitcoin-only emulator: Bitcoin signing works, the coin table contains only Bitcoin/Testnet, altcoin names and handlers (including Zcash privacy) are refused, and OP_RETURN disclosure/refusal paths execute. The same module skipped 11/11 on regular by design. The Bitcoin-only ARM ELF linked, and inspection found no Hive/Zcash signing symbols. Verified in software; physical device pending.
S05-2, regular Zcash inclusion and consent	Orchard viewing keys and shielded signing material derive from the user's seed. The host may receive them only through the regular product's Zcash handlers under the inherited confirmation contract; the on-device observer must see shielded output details.	Regular CMake selects ZCASH_PRIVACY=1, adds <code>zcash.c</code> , and message registration includes the Zcash privacy rows. The regular ARM ELF contains Zcash and Hive handler symbols. The targeted regular host run passed 12 Zcash device tests , including FVK consent, known vectors and shielded output review; the regular native Zcash crypto suite passed 72/72 . Zcash tests skipped on Bitcoin-only, consistent with its exclusion. This unit changes registration, not the inherited Zcash signing internals. Verified in emulator; physical OLED and signing pending.
S05-3, product identity and release provenance	Release operators and users observe filenames, variant labels and hash manifests. A wrong regular filename or a claim that the Bitcoin-only builder cannot take its actual flag can lead an operator to compare the wrong product to a manifest.	Release matrix uses an empty suffix for regular and -bitcoin-only for the second image. The original release body nevertheless named <code>-full.bin</code> and said <code>release.sh</code> took no variant argument, while the script passed extra CMake flags. Audit commit <code>be2c04139</code> corrects both statements and the script comment. <code>actionlint</code> and <code>bash -n</code> pass; both actual ARM build flags and product outputs were exercised locally. No release tag or draft-release job was run. Fixed in source; publication verification remains a release gate.
S05-4, 7.15 report gate	Release operators rely on the generated report and exact-source manifest before signing. Its validator must distinguish staged, explicitly absent controls from accidental missing tests; a failed report must fail the release evidence gate.	CI run 35939578582 on the first audit code head and run 35940214374 on the frozen first report both failed the report/final gates because K8, K8b and K9 storage KDF checks were missing. Python integration had the explicit <code>storage-v19-kdf</code> staged-capability inventory, but <code>generate-test-report</code> did not inherit it. Commit <code>86ecb29ec</code> moves one inventory to workflow scope. With downloaded JUnit from run 35939578582 , the 7.15 validator reproduced the three missing-storage failures without the inventory and passed with the workflow's exact inventory. Its six report-variant tests also passed. This does not declare KDF V19 implemented; it records an explicit staged omission. Fixed locally; new exact-head hosted CI belongs in the PR body and main claim.

The common abort hook still clears Zcash state in regular firmware; in Bitcoin-only the Zcash handler and state are absent. The existing storage-band tests passed in both native suites. The product boundary does not claim that firmware cannot be replaced with a different product by a signed-device upgrade; the production upgrade path and physical checks are separate release acceptance.

4. Verification and skips

Pinned builder: `kktech/firmware@sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2`. Local code builds were on the rebased Stack 05 source with only a later workflow-note/comment change; firmware implementation, flags and dependency pins were unchanged by `be2c04139`.

Check	Result	Evidence and limit
Regular native	Pass: firmware 435/435, board 19/19, crypto 18/18, Zcash crypto 72/72	Docker emulator build and fresh test process; Zcash unit suite is registered in regular.
Bitcoin-only native	Pass: firmware 121/121, board 19/19, crypto 18/18	-DKK_BITCOIN_ONLY=ON; Zcash firmware suite and other non-Bitcoin suites intentionally absent.
ARM MinSizeRel	Pass: both <code>firmware.keepkey.elf</code> linked	Regular ELF 097d324d0c450c733cdf315fd442cb60cd88fe086df7b35b481c2156c9e2de98; Bitcoin-only ELF a3ac7bd7aee5a8b1d70432f406f9a893ce8ea0cdab96b2f7b63909d16f5e7d2c. Linker checks the 16 KiB runtime RAM margin.
Targeted host	Pass: regular Zcash device 12/12; Bitcoin-only boundary 11/11	Separate matching emulator images on isolated Docker networks. Opposite-variant tests skipped by design.
Full host	Pass: regular 642 passed, 188 skipped; Bitcoin-only 341 passed, 489 skipped	Same explicit <code>KK_RELEASE_MISSING_CAPABILITIES</code> inventory as <code>.github/workflows/ci.yml</code> . JUnit source SHA256 and every skipped test/reason are in <code>715-05-skips-20260924.tsv</code> .
Report validator and lint	Pass: six report-variant tests; actual hosted JUnit from run 35939578582 fails without and passes with the shared staged inventory; <code>actionlint</code> on CI/release workflows, <code>bash -n</code> on the release builder, <code>git diff --check</code>	The first two hosted runs failed their report/final gates as recorded above. A new exact-head run must verify the workflow fix. No tag-triggered release job or physical OLED observation.

Full-host JUnit SHA256: regular `aaaa49ebe6845463c92c6834237f528b034fa3af6cf50a91065840fa78fab5aa`; Bitcoin-only `277e78ec0055d83da0bb3dbd43e1cef6e770108b97c9d374e93ed3d87ff56289`. The named TSV SHA256 is `571c60a29aec35cc18d2c78ca296aabd0ffedbc8ed2b22bd1b1ad9906d1fa55f` and includes **all 677 skips**. Of the regular skips, 81 are explicitly staged ERC-7730 runtime controls, 11 are Bitcoin-only-only tests, 14 require 7.16, and 5 storage restart tests lacked a locally mounted emulator binary. In Bitcoin-only, 235 require full firmware, 81 are staged ERC-7730 controls, and Zcash/Hive/TON/Solana/TRON skips reflect excluded handlers. Both local runs lacked the Compose-mounted binary used by hosted storage restart tests; hosted CI must distinguish those five skips and provide the exact-head JUnit and report artifacts. Dylib-only tests and physical unplug/replug remain separate from the UDP emulator run.

5. Frozen report and checkpoint boundary

This Markdown is the source for the matching three-page PDF. At freeze, check every rendered page for legibility, the live base/head and exact adjacent diff, `git diff --check`, and the main-worktree `scripts/release/check-code-review-diff.sh` code-bearing gate. Record the containing report SHA, exact-head hosted CI result and artifacts, current review status and request count in PR #858 and the main-worktree claim. Those facts change after a report is committed; they are deliberately kept out of this immutable evidence snapshot. No Copilot request is part of this report. Implementation, local targeted checks, local native/ARM/host integration, and software adversarial variant checks passed; physical device, predecessor product integration, signed release and promotion remain open.